

MISP

INTELLIGENCE SHARING

Inleiding tot het Delen van Cybersecurity Informatie

MISP - Intelligence Sharing

CIRCL / Team MISP Project

MISP Project

https://www.misp-project.org/

CRI MISP 2024

Agenda

- Agenda and details available
  https://tinyurl.com/CRI-MISP

MISP, bekeken vanuit een praktisch voorbeeld

- In 2012 werd tijdens een werkgroep voor malware analyse duidelijk dat we werkten aan de analyse van dezelfde malware.
- We wilden onze informatie op een eenvoudige en geautomatiseerde manier met elkaar delen **om dubbel werk te voorkomen**.
- Christophe Vandeplas (toen werkzaam bij het CERT voor de Belgische Defensie) toonde ons zijn werk aan een platform dat uiteindelijk MISP werd.
- De eerste versie van het MISP-platform werd gebruikt door de MALWG en met hulp van **de toenemende feedback van gebruikers** konden we een verbeterd platform bouwen.
- MISP is nu uitgegroeid tot een platform waar de **ontwikkeling gestuurd wordt vanuit de gemeenschap**.

over CIRCL

Het Computer Incident Response Centre Luxembourg (CIRCL) is een overheids initiatief om een antwoord te bieden op computerbeveiligingsbedreigingen en -incidenten.

CIRCL is het CERT voor de particuliere sector, gemeenten en niet-gouvernementele entiteiten in Luxemburg en wordt beheerd door securitymadein.lu g.i.e.

MISP en CIRCL

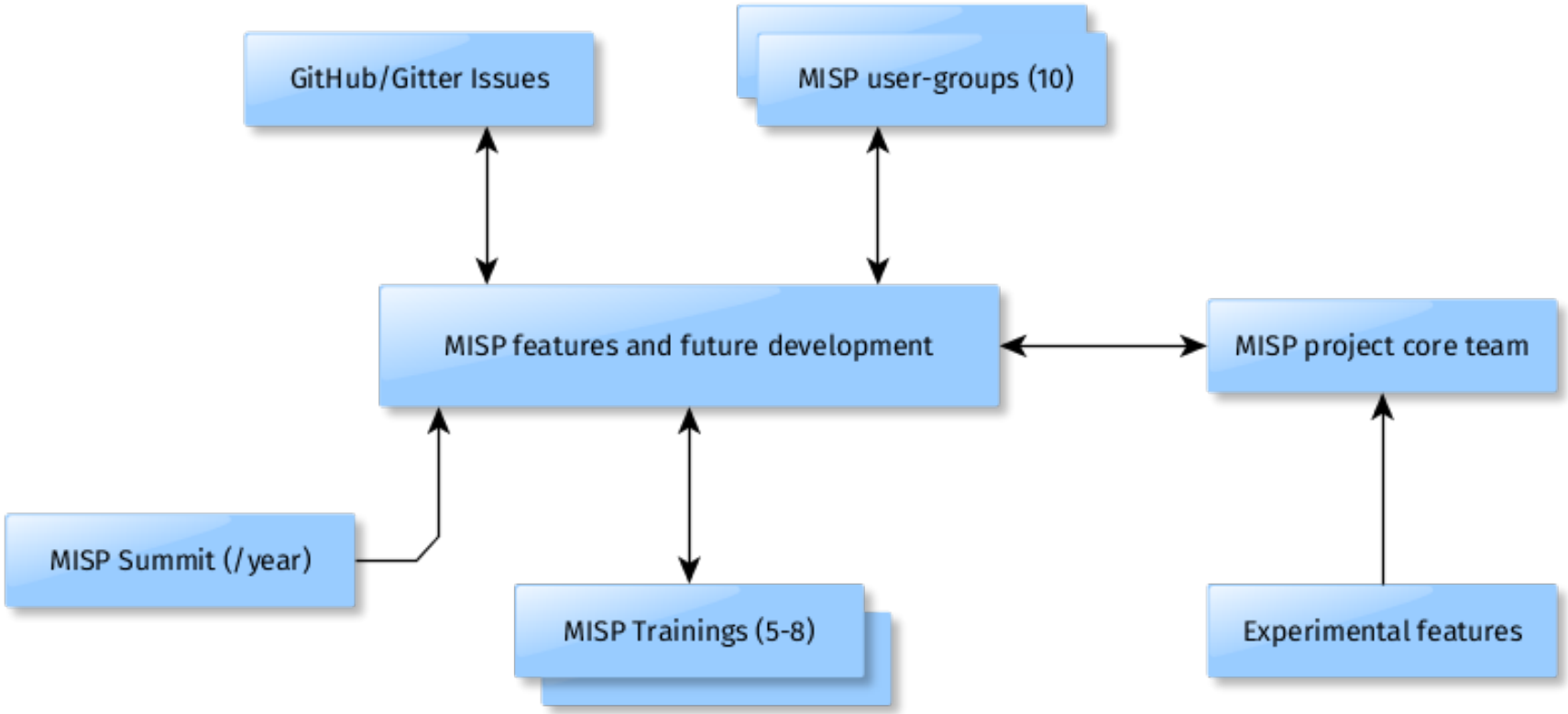
- CIRCL is gemandateerd door het ministerie van Economische Zaken en treedt op als het Luxemburgse nationale CERT voor de particuliere sector.
- CIRCL leidt de ontwikkeling van het Open Source MISP-platform voor het delen van dreigingsinformatie. Dit platform is wereldwijd gebruikt door veel militaire en inlichtingengemeenschappen, privébedrijven, de financiële sector, nationale CERT's en LEA's.
- **CIRCL beheert meerdere grote MISP-gemeenschappen die dagelijkse actief zijn in het delen van dreigingsinformatie**.

Co-financed by the European Union
Connecting Europe Facility

Ontwikkeling gebaseerd op praktische feedback van de gebruikers

- Er zijn veel verschillende soorten gebruikers van een informatie-uitwisselingsplatform zoals MISP:
  - **Malware-analysten** die bereid zijn om de indicatoren van hun analyse met collega's te delen.
  - **Beveiligingsanalisten** die voor operationele beveiliging zoeken naar indicatoren, deze valideren en gebruiken.
  - **Informatie-analysten** die informatie verzamelen over specifieke vijandige groepen.
  - De **politie** die vertrouwt op indicatoren om digitale onderzoeken te ondersteunen of op te starten.
  - **Risico analyse teams** die meer willen weten over nieuwe dreigingen, de waarschijnlijkheid van deze dreigingen en of deze dreigingen werden vastgesteld.
  - **Fraude analysten** die bereid zijn om indicatoren te delen om financiële fraude op te sporen.

Het beheermodel van MISP



Verschillende objectieven

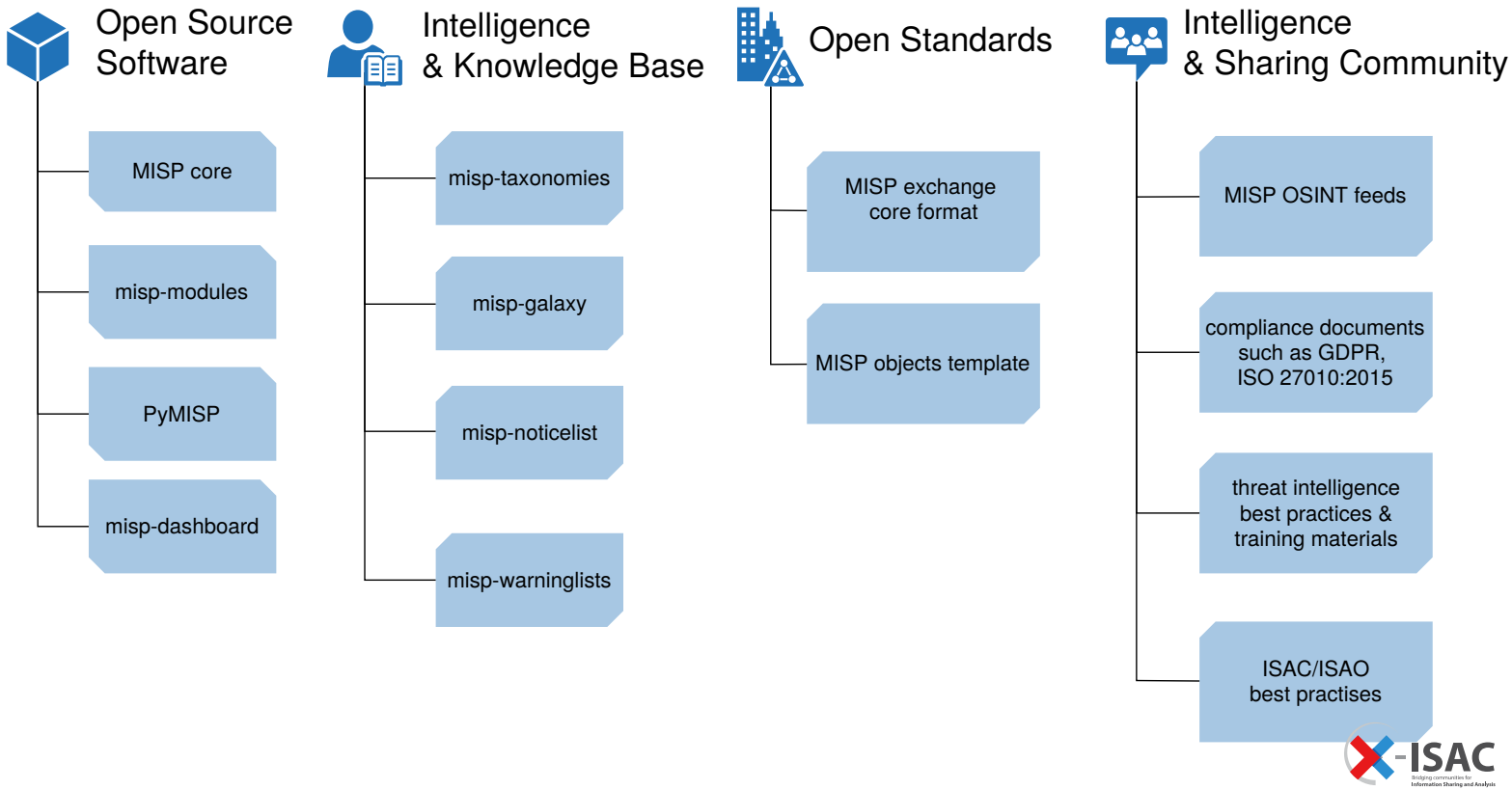
- Delen van indicatoren voor **detectie** doeleinden.
  - 'Heb ik geïnfecteerde systemen in mijn infrastructuur of onder mijn beheer?'
- Delen van indicatoren om te **blokkeren**.
  - 'Ik gebruik deze attributen om verkeer te blokkeren of om verkeer om te leiden.'
- Delen van indicatoren om **informatie te verzamelen**.
  - 'Informatie verzamelen over campagnes en aanvallen. Zijn deze campagnes met elkaar verbonden? Zijn ze gericht op mij? Wie zijn de tegenstanders?'
- $\rightarrow$ Deze doelstellingen kunnen soms tegenstrijdig zijn

Moeilijkheden bij het delen

- De problemen met het delen van informatie zijn vaak niet zozeer van technische aard maar eerder een kwestie van **sociale interacties** (b.v. **vertrouwen**).
- Juridische restricties[1]
  - "Ons wettelijk kader staat ons niet toe om informatie te delen."
  - "Het risico op een informatielek is te hoog en het is te riskant voor onze organisatie of partners."
- Praktische beperkingen
  - "We hebben geen informatie om te delen."
  - "We hebben geen tijd om indicatoren te verwerken of om er te delen."
  - "Ons classificatie model past niet in uw model."
  - "De middelen voor het delen van informatie zijn gebonden aan een specifiek formaat en we gebruiken een ander formaat."

[1] https://www.misp-project.org/compliance/

MISP Project Overzicht

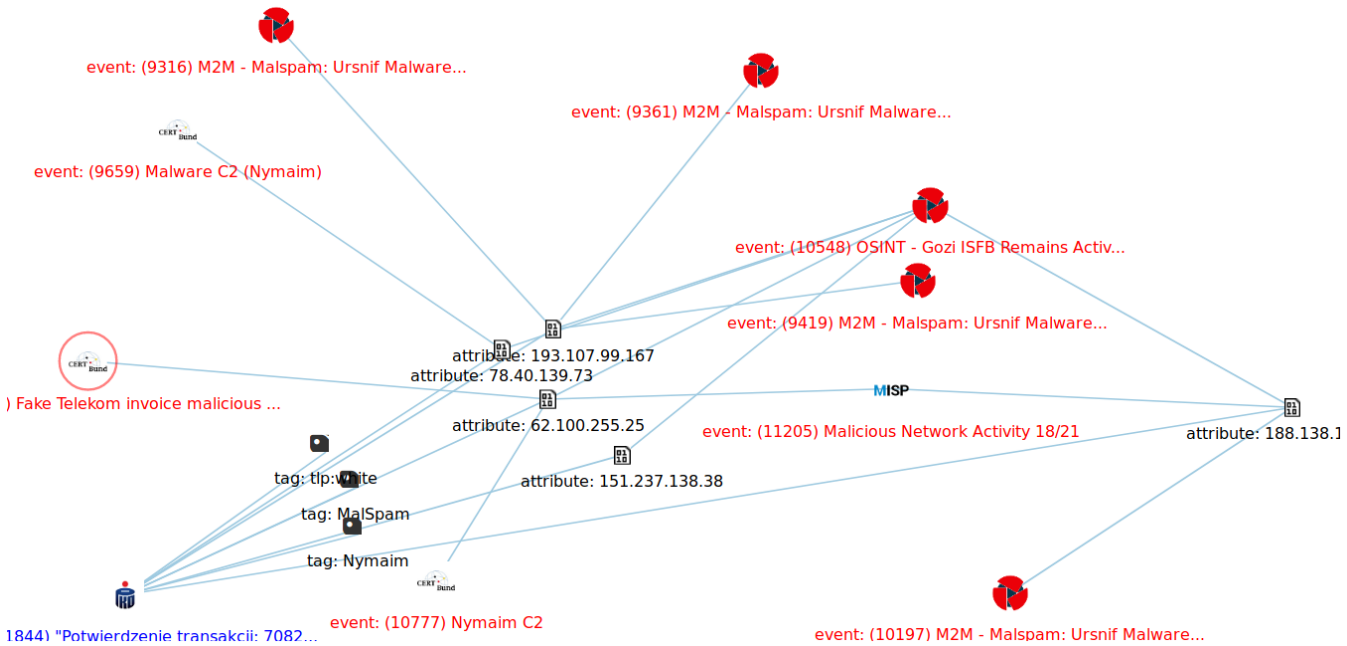


MISP functies

- MISP[2] is open source software voor het delen van dreigings-informatie.
- MISP heeft **een groot aantal functionaliteiten** die gebruikers ondersteunen bij het maken, samen werken aan en het delen van bedreigingsinformatie - bijv. flexibele groepen voor het delen van informatie, **automatische correlatie van gegevens**, importhulp, event distributie en voorstelling voor verbetering van attributen.
- Er is ondersteuning voor diverse formaten van IDS / IPS systemen (b.v. Suricata, Bro, Snort), SIEMs (b.v. CEF), host scanners (b.v. OpenIOC, STIX, CSV, yara), analyse tools (b.v. Maltego) of om DNS policies te implementeren (b.v. RPZ).
- Er is een breed aanbod aan MISP modules[3] voor uitbreiding, import en export functionaliteiten.

[2] https://github.com/MISP/MISP
[3] https://www.github.com/MISP/misp-modules

Correlaties : een hulpmiddel voor analysten



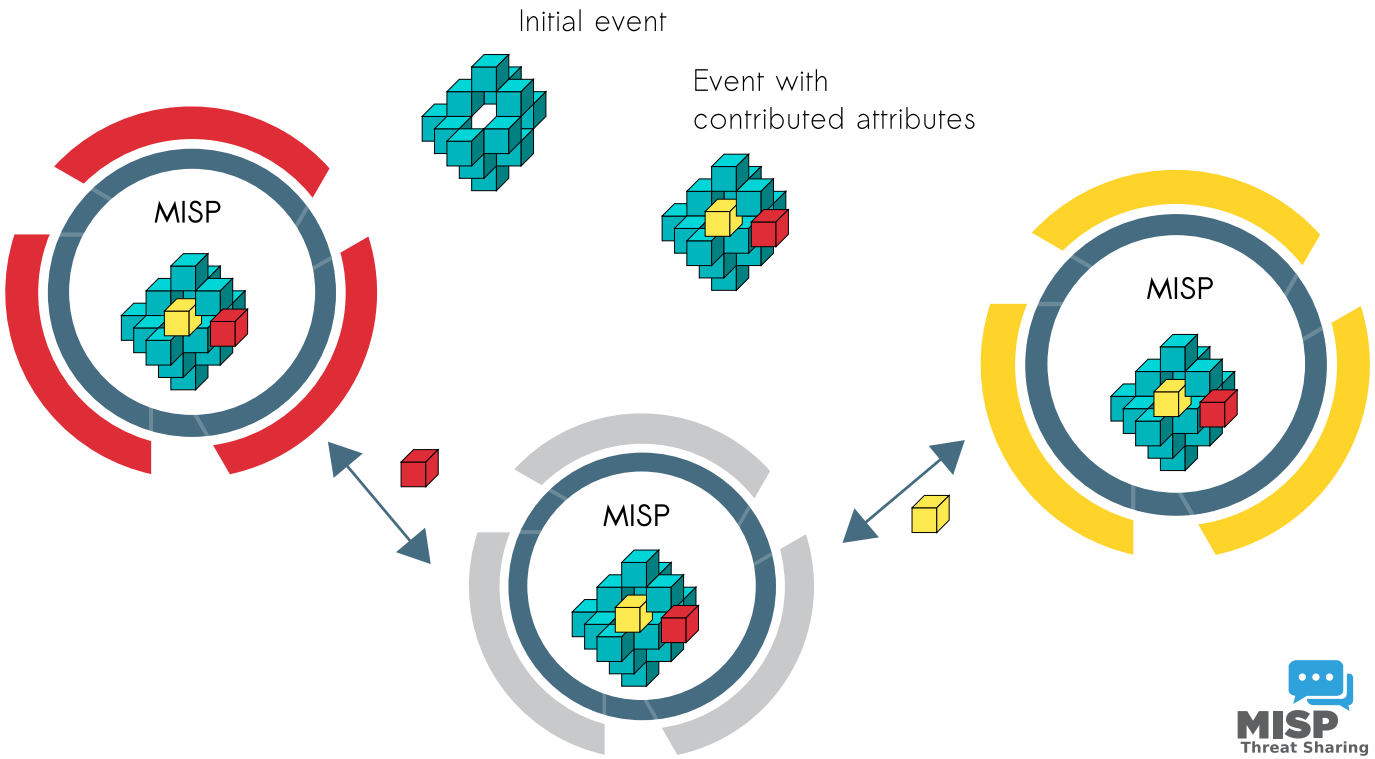
- Voor het **bevestigen van een bevinding** (b.v. is dit dezelfde campagne?), **of een analyse** (b.v. hebben andere analysten dezelfde hypothesis?), **bevestigen van een specifiek aspect** (b.v. werden deze sinkhole IP adressen gebruikt voor een campagne?) of het simpelweg uitzoeken of een **dreiging nieuw of onbekend is in je omgeving**.

Groepen die MISP gebruiken

- In het algemeen gaan gebruikers informatie delen met een groep met dezelfde objectieven of waarden.
- CIRCL beheert meerdere MISP-instanties met een aanzienlijke gebruikersbasis (meer dan 950 organisaties met meer dan 2400 gebruikers).
- **Vertrouwde** (gesloten) groepen die MISP gebruiken in een soort "eiland" modus (als een geïsoleerd systeem) of als een deels geconnecteerd systeem.
- De **financiële sector** (banken, ISACs, organisaties die betalingen verwerken) gebruikt MISP als een mechanisme voor het delen van informatie.
- **Militaire en internationale organisaties** (NATO, militaire CSIRTs, n/g CERTs,...).
- **Security bedrijven** die hun eigen gemeenschap starten (b.v. Fidelis) of een koppeling hebben met een MISP gemeenschap (b.v. OTX).

MISP basisfuncties voor gedistribueerd delen

- De kernfunctionaliteit van MISP is het delen van informatie waarbij iedereen zowel een consument als een producent (bijdrager) kan zijn.
- Dit heeft als voordeel dat iedereen snel kan deelnemen, zonder de directe verplichting om zelf bij te dragen.
- Er is een lage drempel om het systeem te leren kennen.



Events, Objecten en Attributen in MISP

- Een MISP event is een verzameling van contextueel verbonden informatie.
- Attributen[4] starten initieel met een standaard groep van "cyber security" indicatoren.
- Attributen zijn puur **gebaseerd op gebruik**. De verbetering gebeuren voornamelijk op basis van praktische noden (**financiële indicatoren** in versie 2.4).
- Objecten zijn samengestelde attributen die verschillende datapunten beschrijven, opgebouwd uit templates van de gemeenschap en de gebruikers.
- Galaxies zorgen voor een granulaire context, classificatie en categorisatie van de gegevens gebaseerd op **dreigings actoren**, **preventie maatregelen** en de hulpmiddelen gebruikt door tegenstanders.

[4] attributen kunnen alles zijn zolang ze bijdragen aan het beschrijven van de intentie van het event, b.v. indicatoren, kwetsbaarheden ...

Delen van Technieken van Aanvallers

- MISP heeft integratie op zowel event als attribuut niveau voor MITRE's Adversarial Tactics, Techniques, and Common Knowledge (ATT&CK).



Pre Attack - Attack Pattern | **Enterprise Attack - Attack Pattern** | Mobile Attack - Attack Pattern

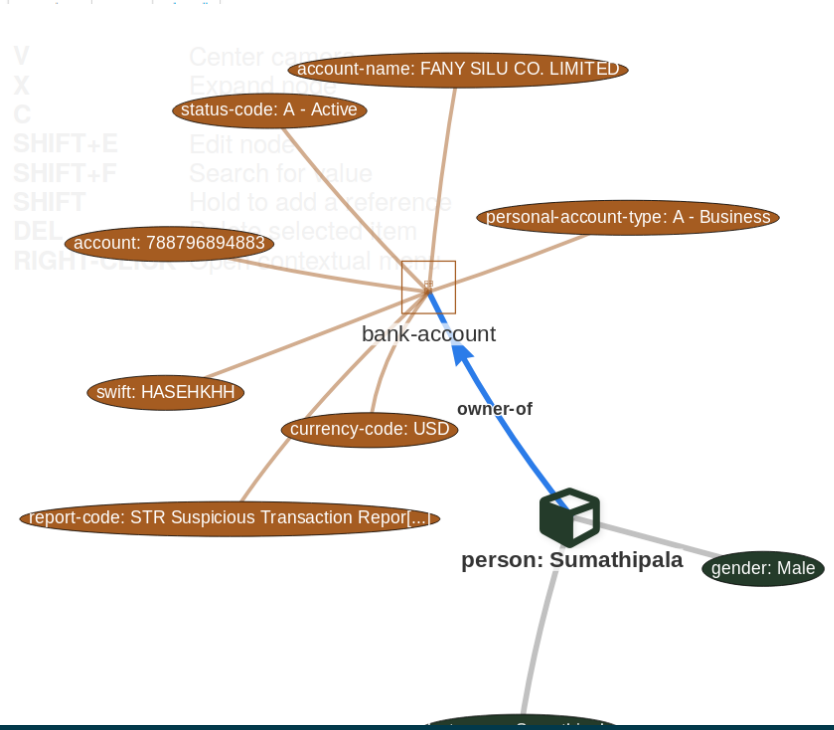
0 — 11 — Show all

Initial access	Execution	Persistence	Privilege escalation	Defense evasion	Credential access	Discovery	Lateral movement	Collection	Exfiltration	Command and control
Spearphishing Attachment	Scripting	Screensaver	File System Permissions Weakness	Process Hollowing	Securityd Memory	Password Policy Discovery	AppleScript	Data from Information Repositories	Exfiltration Over Alternative Protocol	Standard Application Layer Protocol
Spearphishing via Service	Command-Line Interface	Login Item	AppCert DLLs	Code Signing	Input Capture	System Network Configuration Discovery	Distributed Component Object Model	Data from Removable Media	Exfiltration Over Command and Control Channel	Communication Through Removable Media
Trusted Relationship	User Execution	Trap	Application Shimming	Rootkit	Bash History	Process Discovery	Pass the Hash	Man in the Browser	Data Compressed	Custom Command and Control Protocol
Replication Through Removable Media	Regsvcs/Regasm	System Firmware	Scheduled Task	NTFS File Attributes	Exploitation for Credential Access	Network Share Discovery	Exploitation of Remote Services	Data Staged	Automated Exfiltration	Multi-Stage Channels
Exploit Public-Facing Application	Trusted Developer Utilities	Registry Run Keys / Start Folder	Startup Items	Exploitation for Defense Evasion	Private Keys	Peripheral Device Discovery	Remote Desktop Protocol	Screen Capture	Scheduled Transfer	Remote Access Tools
Spearphishing Link	Windows Management Instrumentation	LC_LOAD_DYLIB Addition	New Service	Network Share Connection Removal	Brute Force	Account Discovery	Pass the Ticket	Email Collection	Data Encrypted	Uncommonly Used Port
Valid Accounts	Service Execution	LSASS Driver	Sudo Caching	Process Doppelgänging	Password Filter DLL	System Information Discovery	Windows Remote Management	Clipboard Data	Exfiltration Over Other Network Medium	Multilayer Encryption
Supply Chain Compromise	CMSTP	Rc.common	Process Injection	Disabling Security Tools	Two-Factor Authentication Interception	System Network Connections Discovery	Windows Admin Shares	Video Capture	Exfiltration Over Physical Medium	Domain Fronting
Drive-by Compromise	Control Panel Items	Authentication Package	Bypass User Account Control	Timestomp	LLMNR/NBT-NS Poisoning	Network Service Scanning	Remote Services	Audio Capture	Data Transfer Size Limits	Data Obfuscation
Hardware Additions	Dynamic Data Exchange	Component Firmware	Extra Window Memory Injection	Modify Registry	Credentials in Files	File and Directory Discovery	Taint Shared Content	Data from Network Shared Drive		Connection Proxy
	Source	Windows Management Instrumentation Event Subscription	Setuid and Setgid	Indicator Removal from Tools	Forced Authentication	Security Software Discovery	Application Deployment Software	Data from Local System		Commonly Used Port
	Space after Filename	Change Default File	Launch Daemon	Hidden Window	Keychain	System Service Discovery	Third-party Software	Automated Collection		Data Encoding

Ondersteuning voor een specifiek datamodel

Filters: All | File | Network | Financial | Proposal | Correlation | Warnings | Include deleted attributes | Show context fields

Date	Org	Category	Type	Value	Tags	Galaxies	Comment	Correlate	Related Events
2018-09-28		Name: bank-account References: 0							
2018-09-28		Other	status-code: text	A - Active	+	Add		☐	
2018-09-28		Other	report-code: text	STR Suspicious Transaction Report	+	Add		☐	
2018-09-28		Other	personal-account-type: text	A - Business	+	Add		☐	
2018-09-28		Financial fraud	swift: bic	HASEHKHH	+	Add		☑	3849 11320 11584
2018-09-28		Financial fraud	account: bank-account-nr	788796894883	+	Add		☑	
2018-09-28		Other	account-name: text	FANY SILU CO. LIMITED	+	Add		☑	
2018-09-28		Other	currency-code: text	USD	+	Add		☐	



Terminilogie van indicatoren

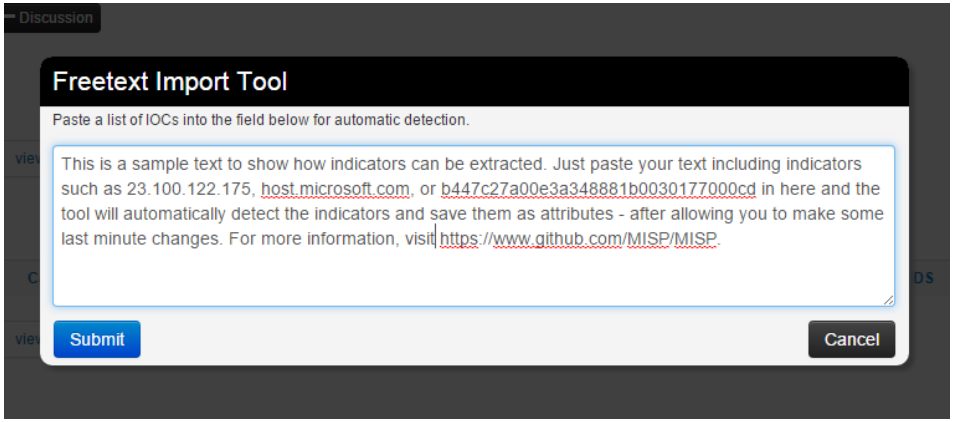
- Indicatoren[5]
  - Indicatoren beschrijven een patroon dat kan gebruikt worden om verdachte of kwaadaardige traffiek te detecteren.
- Attributen in MISP kunnen netwerk indicatoren (b.v. IP adressen), systeem indicatoren (b.v. tekst in het geheugen) of zelfs bank gegevens zijn.
  - Een **type** (b.v. MD5, url) is hoe een attribuut is beschreven.
  - Een attribuut behoort altijd tot een categorie (b.v. Payload delivery). Deze categorie plaatst het attribuut in een bepaalde context.
    - **Een categorie bepaalt de context** van een attribuut.
  - De IDS instelling op een attribuut bepaald of **dit attribuut automatisch** zal gebruikt worden voor **detectie** doeleinden.

[5] IoC (Indicator of Compromise) zijn een onderdeel van de indicatoren

Ondersteuning voor het werken met MISP

- Gebruikers kunnen events of attributen bijvoegen via zowel de web interface, de API als via een vrije tekst veld.
  - Met PyMISP kunt u MISP via Python en scripts gebruiken om gegevens op te vragen, toe te voegen en te verwerken.
- Een bijdrage kan gebeuren door rechtstreeks een event aan te maken maar gebruikers kunnen ook de eigenaar van een event een **update voorstellen voor attributen**.
- Gebruikers zijn **niet gedwongen om één interface te gebruiken om gegevens aan MISP bij te voegen**.

Voorbeeld: Vrije tekst import in MISP



Freetext Import Results

Below you can see the attributes that are to be created. Make sure that the categories and the types are correct, often several options will be offered based on an inconclusive automatic resolution.

Value	Category	Type	IDS	Comment	Actions
23.100.122.175	Network activity	ip-dst	☑	Imported via the freetext import.	✖
host.microsoft.com	Network activity	hostname	☑	Imported via the freetext import.	✖
b447c27a00e3a348881b0030177000cd	Payload delivery	md5	☑	Imported via the freetext import.	✖
https://www.github.com/MISP/MISP	Network activity	url	☑	Imported via the freetext import.	✖

Submit

ip-dst → ip-src Change all

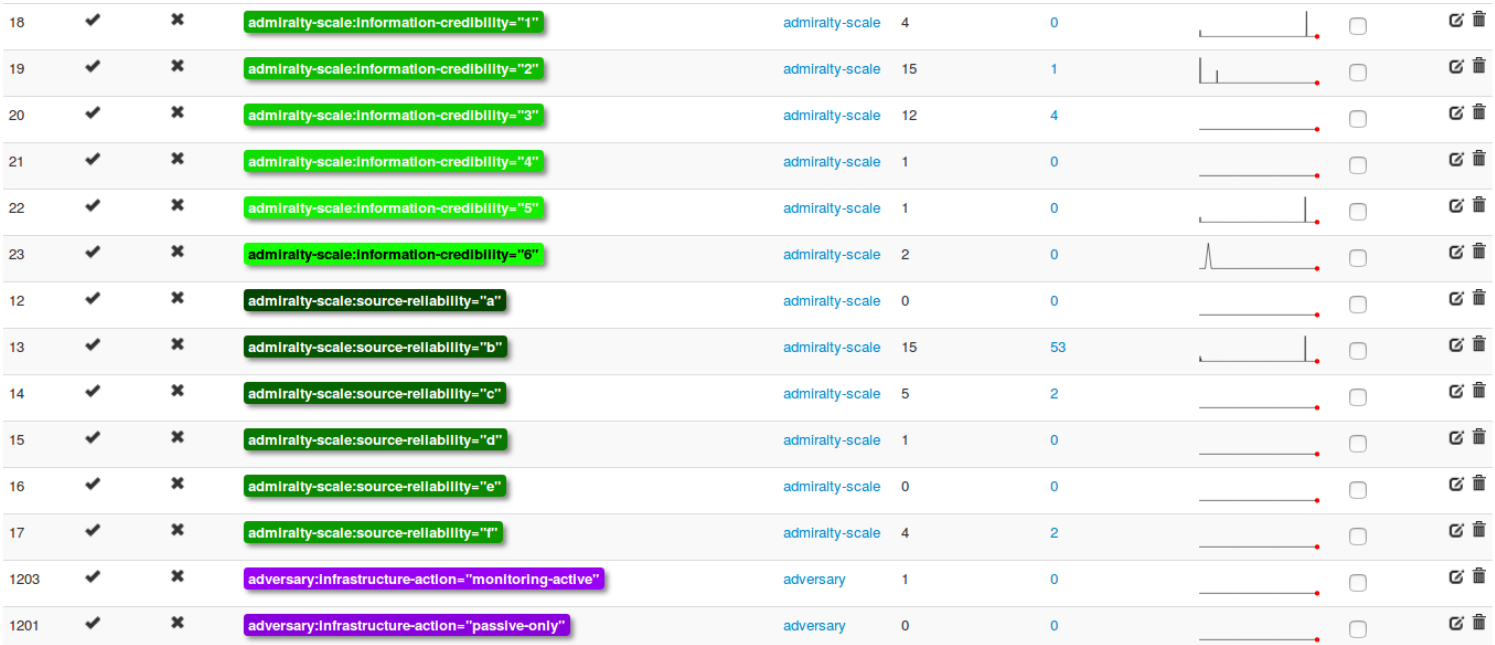
Update all comment fields Change all

Filters: All | File | Network | Financial | Proposal | Correlation

Date	Org	Category	Type	Value	Comment	Related Events	IDS	Distribution	Actions
2016-02-24		Network activity	hostname	host.microsoft.com	Imported via the freetext import.		Yes	Inherit	
2016-02-24		Network activity	ip-dst	23.100.122.175	Imported via the freetext import.	298	Yes	Inherit	
2016-02-24		Network activity	url	https://www.github.com/MISP/MISP	Imported via the freetext import.		Yes	Inherit	
2016-02-24		Payload delivery	md5	b447c27a00e3a348881b0030177000cd	Imported via the freetext import.		Yes	Inherit	

Ondersteuning voor classificaties

- Het gebruik van tags is een simpele manier om een classificatie toe te voegen aan een event of attribuut.
- Een **classificatie moet globaal** in gebruik zijn om ook efficient te zijn.
- Gebruikers kunnen via een flexibel tagging systeem kiezen uit de meer dan 42 bestaande taxonomieën of ze kunnen hun eigen taxonomie bijvoegen.

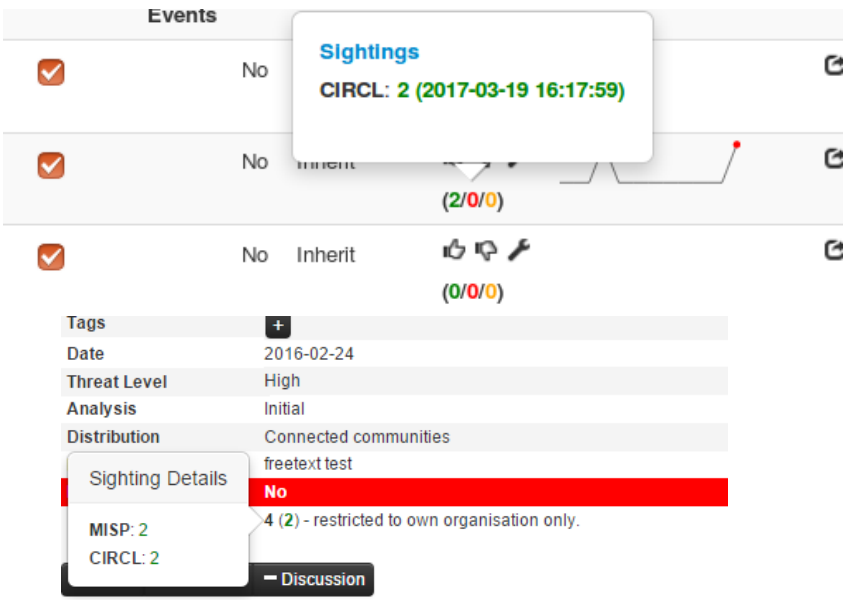


18	✔	✖	admiralty-scale:information-credibility="1"	admiralty-scale	4	0			
19	✔	✖	admiralty-scale:information-credibility="2"	admiralty-scale	15	1			
20	✔	✖	admiralty-scale:information-credibility="3"	admiralty-scale	12	4			
21	✔	✖	admiralty-scale:information-credibility="4"	admiralty-scale	1	0			
22	✔	✖	admiralty-scale:information-credibility="5"	admiralty-scale	1	0			
23	✔	✖	admiralty-scale:information-credibility="6"	admiralty-scale	2	0			
12	✔	✖	admiralty-scale:source-reliability="a"	admiralty-scale	0	0			
13	✔	✖	admiralty-scale:source-reliability="b"	admiralty-scale	15	53			
14	✔	✖	admiralty-scale:source-reliability="c"	admiralty-scale	5	2			
15	✔	✖	admiralty-scale:source-reliability="d"	admiralty-scale	1	0			
16	✔	✖	admiralty-scale:source-reliability="e"	admiralty-scale	0	0			
17	✔	✖	admiralty-scale:source-reliability="f"	admiralty-scale	4	2			
1203	✔	✖	adversary:infrastructure-action="monitoring-active"	adversary	1	0			
1201	✔	✖	adversary:infrastructure-action="passive-only"	adversary	0	0			

Ondersteuning voor het delen in MISP

- Delegeren van de publicatie van events naar andere organisaties (sinds MISP 2.4.18).
  - Deze andere organisatie kan dan eigenaar worden van het event en op deze manier zorgen voor de **pseudo-anonimiteit van de oorspronkelijke organisatie**.
- Definiëren van groepen om specifieke informatie mee te delen (vanaf 2.4).
  - De gemeenschappen om mee te delen kunnen lokaal of tussen verschillende MISP instanties gebruikt worden.
  - Het delen kan gebeuren op zowel **event** als **attribuut** niveau (b.v. financiële indicatoren met de financiële groepen en cyber security indicatoren met de CSIRT gemeenschap).

Ondersteuning voor waarnemingen



- Gebruikers kunnen via **waarnemingen** de gemeenschap op de hoogte stellen van activiteit gerelateerd aan een indicator.
- Het is mogelijk om negatieve waarnemingen (false positives) en waarnemingen met een vervaldatum in te geven.
- Waarnemingen kunnen gebeuren via de web interface, de API of door STIX waarnemings-documenten te importeren.
- Er zijn verschillende toepassingen om indicatoren te rangschikken op basis van waarnemingen.

Verbeteringen voor het delen van informatie in MISP

- Valse positiven (false-positive) blijven een terugkerende uitdaging bij het delen van informatie.
- Vanaf MISP 2.4.39 hebben we het concept van misp-warninglists[6] geïntroduceerd om de analysten te ondersteunen bij hun dagtaak.
- Dit zijn voorgedefinieerde lijsten van indicatoren die vaak een valse positieve zijn, zoals bijvoorbeeld RFC1918 netwerken of publieke DNS servers.

[6] https://github.com/MISP/misp-warninglists

Ondersteuninng voor het delen binnen en buiten een organisatie

- Zelfs binnen één en dezelfde omgeving kunnen er verschillende use cases zijn voor het gebruik van MISP (b.v. groepen die MISP gebruiken voor dynamische malware analyse en correlatie, andere groepen die het dan weer gebruiken voor het versturen van meldingen).
- Vanaf MISP 2.4.51, is er de optie om **lokale MISP** servers met elkaar te verbinden. Zo kan je verschillende niveaus van delen voorkomen en kan je van een gemengde synchronisatie gebruik maken, zowel binnen als buiten de organisatie.
- Er is ondersteuning voor feeds voor synchronisatie tussen vertrouwde en niet vertrouwde netwerken.

Starten met MISP en indicatoren

- We onderhouden de standaard CIRCL OSINT-feeds (TLP:WHITE geselecteerd uit onze gemeenschappen) zodat gebruikers snel aan de slag kunnen gaan met MISP.
- Het formaat van de OSINT-feed is gebaseerd op standaard MISP JSON-uitvoer van een externe TLS / HTTP-server.
- Aanvullende contentproviders kunnen hun eigen MISP-feeds leveren. (`https://botvrij.eu/`).
- Dit laat gebruikers toe om hun MISP-installaties te **testen en te synchroniseren met een echte gegevensset**.
- Dit kan bijdragen aan andere bronnen van dreigings informatie en helpt ook bij de analyze naar overlappende data[7].

[7] Een steeds terugkerende uitdaging bij het delen van informatie

Conclusie

- **De manier van informatie delen onstaat voornamelijk uit het gebruik** en het volgen van bestaande voorbeelden.
- MISP is uiteindelijk slechts een hulpmiddel, het belangrijkste is nog altijd de manier hoe je de informatie deelt. De tool moet u daarbij zo transparant mogelijk ondersteunen tijdens uw werk.
- Gebruikers moeten MISP kunnen aanpassen zodat zij een oplossing hebben voor de noden van hun gemeenschap.
- Het MISP project combineert open source software, open standaarden, best practices en gemeenschappen om informatie deling te realiseren.